

Deliberation SAN-2024-002 of January 31, 2024

National Commission for Information Technology and Freedoms

Nature of the deliberation: Sanction

Legal status: In force

Date of publication on Légifrance: Tuesday, February 13, 2024

Deliberation of the restricted formation No. SAN-2024-002 of January 31, 2024, concerning the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS

The National Commission for Information Technology and Freedoms, convened in its restricted formation composed of Mr. Alexandre LINDEN, president, Mr. Philippe-Pierre CABOURDIN, vice-president, Ms. Christine MAUGÜÉ, and Messrs. Alain DRU and Bertrand du MARAIS, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of personal data and the free movement of such data;

Considering Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector;

Considering Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms, notably its Articles 20 and following;

Considering Decree No. 2019-536 of May 29, 2019, amended, taken for the application of Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms;

Considering Deliberation No. 2013-175 of July 4, 2013, adopting the internal regulations of the National Commission for Information Technology and Freedoms;

Considering Decision No. 2021-193C of June 29, 2021, of the president of the National Commission for Information Technology and Freedoms, charging the Secretary General to carry out or have carried out a verification mission of the personal data processing implemented by the company or on its behalf;

Considering the decision of the president of the National Commission for Information Technology and Freedoms designating a rapporteur before the restricted formation, dated February 6, 2023;

Considering the report of Ms. Sophie LAMBREMON, rapporteur commissioner, notified to the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS on July 20, 2023;

Considering the written observations submitted by the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS on September 8, 2023;

Considering the response observations from the rapporteur on October 6, 2023;

Considering the response observations from the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS on November 2, 2023;

Considering the other documents in the file;

Present at the session of the restricted formation on December 21, 2023:

- Ms. Sophie LAMBREMON, commissioner, heard in her report;

As representatives of the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS:

- [...];

The company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS having spoken last;

The restricted formation adopted the following decision:

I. Facts and Procedure

1. The company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS (hereinafter "the company"), whose registered office is located at 45 rue du Cardinal Lemoine in Paris (75005), was registered in the trade and companies register on November 14, 1975. Its revenue amounted in 2021 to [...] euros with a net result of [...] euros and in 2022 to [...] euros with a net result of [...] euros.

2. The company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS provides individuals with a range of publications and services enabling them to conclude real estate transactions without intermediaries. The company publishes the website www.pap.fr, which offers individuals the opportunity to publish or consult real estate listings and access various tools for managing real estate

projects (legal assistance, real estate coaching, credit calculations, price per square meter, evaluation of the price of properties for sale, and notary fees).

3. Two control missions took place under Decision No. 2022-041C of March 2, 2022, of the president of the CNIL to verify the company's compliance with...

the absence of such objections, the project of decision is definitive.¹⁹ En conséquence, la Commission a adopté la décision finale le 15 février 2024.²⁰ Cette décision est notifiée à la société et aux autorités de contrôle concernées.

B. Sur les manquements constatés²¹. Les manquements aux articles 5-1-e), 12, 13, 28 et 32 du RGPD ainsi qu'à l'article L.34-5 du code des postes et des communications électroniques sont détaillés comme suit :

1. Manquement à l'article 5-1-e) du RGPD : La société n'a pas respecté le principe de limitation de la conservation des données, en conservant les données des utilisateurs au-delà de la durée nécessaire.
2. Manquement à l'article 12 du RGPD : La société n'a pas fourni aux utilisateurs des informations claires et accessibles concernant le traitement de leurs données personnelles.
3. Manquement à l'article 13 du RGPD : La société n'a pas informé les utilisateurs de manière adéquate au moment de la collecte de leurs données personnelles.
4. Manquement à l'article 28 du RGPD : La société n'a pas mis en place un contrat adéquat avec son sous-traitant, ce qui a compromis la protection des données.
5. Manquement à l'article 32 du RGPD : La société n'a pas pris les mesures techniques et organisationnelles appropriées pour assurer un niveau de sécurité adapté au risque.
6. Manquement à l'article L.34-5 du code des postes et des communications électroniques : La société a omis d'obtenir le consentement préalable des utilisateurs pour l'envoi de communications électroniques à des fins de prospection.

C. Sanctions prononcées²². En raison des manquements constatés, la Commission a décidé d'imposer à la société une amende administrative de [montant à préciser] euros.²³ Cette amende doit être payée dans un délai de [délai à préciser] jours à compter de la notification de la décision.²⁴ En outre, la société est tenue de prendre des mesures correctives pour remédier aux manquements identifiés dans un délai de [délai à préciser] jours.

D. Droit de recours²⁵. La société a le droit de contester cette décision devant le Conseil d'État dans un délai de deux mois à compter de sa notification.²⁶ Le recours doit être introduit par voie de requête, conformément aux dispositions du code de justice administrative.

Fait à [lieu], le [date].

[Nom et titre de l'autorité compétente]

[Signature]

****Application of Article 60, Paragraph 6, of the GDPR****

These are deemed to have been approved.

****B. On the breach of the obligation to limit the duration of data retention****

19. Under Article 5-1, e) of the GDPR, personal data must be "kept in a form which permits identification of the data subjects for no longer than is necessary for the purposes for which the personal data are processed."

20. The rapporteur noted that during the on-site inspection, the company indicated that it had defined a data retention policy that varied according to the type of users of the website www.pap.fr. Thus, regarding customer data (individuals using the paid services of the site), the rapporteur noted that the company had defined a retention period of ten years from the date of order acceptance. She observed that the systematic and indiscriminate retention of all account data for ten years did not appear justified in light of the legal obligation arising from the Consumer Code and that the database extraction provided included data related to transactions below 120 euros, the retention of which did not appear justified. Regarding user data (individuals using the free services of the site), the rapporteur noted that while the company had defined a retention period of five years from the date of the last connection to the account, it emerged from the on-site inspection that the company had retained 2,394,538 records for more than five years and less than ten years, and 737,563 records for more than ten years.

21. In defense, regarding the data of customers using paid advertisements, the company specified during the investigation that it retained the advertisement and the email address for ten years for the purpose of complying with legal obligations arising from Articles L.213-1, D.213-1, and D.213-2 of the Consumer Code, combating fraud, and due to the specificities related to real estate activity. It detailed the two paid plans offered to customers: either a contract with no commitment for 59 euros per month, which is considered a unique contract of indefinite duration, or a three-month contract subscribed for 135 euros. For contracts without commitment, estimating that it could not determine in advance the duration of the contract, the company specified that it retained all data related to these contracts for a period of ten years, regardless of the final amount. It further considers that the financial stakes of the advertisements and sales contracts concluded subsequently for amounts well above 120 euros should be taken into account. It also indicated that the retention period for birth years was reduced to twenty-five months and that for data related to an inactive account to three years of inactivity.

22. Regarding user data, the company specified during the investigation that it retained only the email address and the associated account for a period of five years for litigation purposes and combating fraud, and that it had deleted data retained beyond this five-year period.

23. The restricted formation recalls that it is the responsibility of the data controller to define and implement a data retention period that does not exceed what is necessary in light of the purpose for which the data are processed.

24. Regarding relevant durations, by way of illustration, the restricted formation notes that in its framework relating to the processing of personal data implemented for the management of commercial activities, the CNIL specifies that data necessary for the execution of a contract are retained during the contractual relationship and that compliance with a legal obligation incumbent on the organization may, in particular, justify a longer retention period. In the absence of this, retention... must rely on another legal basis provided for in Article 6 of the GDPR.

25. Under Article L. 213-1 of the Consumer Code: "When the contract is concluded electronically and concerns an amount equal to or greater than an amount set by decree, the professional contractor ensures the preservation of the written record that confirms it for a period determined by the same decree and guarantees access to it at any time to its co-contractor if requested."

26. Article D. 213-1 of the same code provides that "[t]he amount mentioned in Article L. 213-1 is set at 120 euros" and Article D. 213-2 states that "[t]he period mentioned in Article L. 213-1 is set at ten years from the conclusion of the contract when the delivery of the good or the execution of the service is immediate. In the contrary case, the period runs from the conclusion of the contract until the date of delivery of the good or the execution of the service and for a duration of ten years from that date."

27. In this case, the restricted formation first notes that, regarding the preservation of customer data, the ten-year retention period from the date of acceptance of the order defined by the company is justified by its legal obligations resulting from the aforementioned Consumer Code for contracts exceeding 120 euros. Thus, the restricted formation considers that, for the three-month contracts offered by the company at a price of 135 euros, the retention of data for a period of ten years is fully justified.

28. On the other hand, the restricted formation notes that, for contracts without commitment at a price of 59 euros per month, the company retains by default the data related to these contracts as soon as they are concluded, even if the total amount paid by the user is less than 120 euros. However, in the case where a customer has only used the company's paid services for one or two months, that is, for an amount less than 120 euros, the data retention period provided for by the Consumer Code would not apply. The restricted formation notes that Article D.213-1 of the Consumer Code expressly states "when the contract (...) concerns an amount equal to or greater than." The only amount to be considered is therefore that of the contract concluded between the company PAP and the customer, especially since the company PAP is a third party to the sales contract concluded between the selling customer and the buyer. Consequently, the restricted formation considers that the retention of customer data in the situation just described is not made mandatory by compliance with the Consumer Code, contrary to what the company indicates.

29. In any case, the restricted formation notes that an extraction of 100 lines corresponding to customer accounts that placed orders more than five years ago shows that 69 of them concerned orders for an amount less than 120 euros. Therefore, the restricted formation considers that the company has retained data from accounts not covered by Article D. 213-1 of the Consumer Code for excessive

30. Next, the restricted formation notes, regarding the retention of user data, that the company has defined a retention period of five years that begins to run from the date of the last connection to the user account. The restricted formation considers that the explanations provided by the company during the investigation justify the retention period for litigation purposes and for combating fraud. 31. Nevertheless, the restricted formation observes that it emerges from the on-site inspection that the company had retained 2,394,538 lines corresponding to user accounts for more than five years from the date of the last connection and less than ten years, and 737,563 lines corresponding to user accounts for more than ten years from the date.

32. The restricted formation notes that it follows from the above that when the retention period is reached, personal data must be deleted. Consequently, it appears from the case files that at the date of the on-site inspection, the company was retaining user account data beyond what was necessary in light of the stated purpose. 33. As a result, the restricted formation considers that the preceding facts constitute a breach of Article 5-1-e) of the GDPR. The restricted formation notes that the company has partially complied during the procedure by applying an adequate retention period for user account data in light of the various purposes pursued by deleting data related to accounts that have been inactive for more than five years. This compliance cannot exempt the company from its liability for the past. C. On the breach of the obligation to inform individuals 34. Article 13 of the GDPR lists the information that must be provided to the data subject when personal data is collected directly from them. This information includes, in particular, the identity of the data controller and their contact details, the purposes of the processing carried out, its legal basis, the recipients or categories of recipients of the data, and the fact that the data controller intends to carry out a transfer of data to a third country. The article also imposes on the data controller, when necessary to ensure "fair and transparent processing" of personal data in this case, to inform individuals about the retention period of the data, the existence of the various rights that individuals have, the existence of the right to withdraw consent at any time, and the right to lodge a complaint with a supervisory authority.

35. In her report, the rapporteur essentially notes that the information provided by the company on the website www.pap.fr, through its page "personal data protection policy," was incomplete or inaccurate, failing to specify the processing to which the legal bases relate, the recipients or categories of recipients of data, the right to lodge a complaint with the CNIL, and the retention periods defined by the company. However, the rapporteur notes that the company has, since the inspections, engaged in a compliance process, without this affecting the breaches for the past. 36. In defense, the company contests the breach. It only claims to have provided the information in an imprecise manner. It indicates that it has complied since the inspections by modifying and completing its personal data protection policy. Regarding the legal bases applicable to the processing, the company mentions a presentation awkwardness. Regarding the mention of recipients or categories of recipients, it considers that it was not required to provide the identity of all data recipients. 37. The restricted formation notes that it follows from the findings made during the inspections that regarding the website www.pap.fr, a personal data protection policy was accessible from the footer of the homepage, a document to which the user account creation form also referred. However, it appears that while the legal bases were indicated, no explanation was provided regarding the processing to which they related. 38. Furthermore, the restricted formation notes, like the rapporteur, that the company indicated the name of only one of its subcontractors, the company [...], which is responsible for payments made on the site. Aside from this case, no information was provided regarding the other recipients or categories of recipients.

personal data. However, the restricted panel notes that it appears from the checks that the company had at least two other subcontractors who were recipients of the personal data. 39. Therefore, the restricted panel considers that the company did not comply with the provisions of Article 13(1) of the GDPR. 40. Next, the restricted panel notes, on the one hand, that this personal data protection policy did not mention the right to lodge a complaint with the CNIL and, on the other hand, that the stated retention periods were inaccurate. 41. However, the restricted panel considers that this information, in that it contributes to ensuring users' control over the processing of their data, is important to guarantee fair and transparent processing. 42. The restricted panel considers that the absence of mention of the

right to lodge a complaint with the CNIL and the imprecision of the information regarding the retention period of users' data in the company's privacy policy constitute a breach of Article 13(2) of the GDPR. 43. Consequently, the restricted panel considers that the company has committed a breach of Article 13 of the GDPR. It specifies that the breach taken into account is the one that was crystallized at the time of the checks and acknowledges that the company has come into compliance. D. On the breach related to the obligation to frame the processing carried out on behalf of the data controller by a legal act 44. Under Article 28, paragraph 3, of the Regulation, the processing carried out by a processor on behalf of a data controller is governed by a contract or any other formalized legal act that defines the subject and duration of the processing, the nature and purpose of the processing, the type of personal data, the categories of data subjects, as well as the obligations and rights of the data controller. This contract also provides the conditions under which the processor undertakes to carry out the processing operations on behalf of the data controller. 45. The rapporteur noted that the contractual documents of the companies [...], subcontractors of the company, did not contain all the mentions required by the aforementioned article. 46. In defense, the company contests the breach concerning the contractual relationship with the company [...]. In this regard, it specifies that the latter is governed by a contract that refers to a data processing agreement, which contains the mentions required by Article 28. Regarding the contract concluded with the company [...], the company indicates that it has concluded an amendment to the contract containing the mentions provided for in Article 28. Finally, the company states that it has terminated the contractual relationship with the company [...]. 47. The restricted panel notes that regarding the contractual documents of the company [...], the company had provided the CNIL delegation with the only contract concluded on November 19, 2021. It subsequently submitted, in response to the sanction report, the data processing agreement referred to in the contract. The restricted panel considers that these contractual documents read as a whole contain all the necessary mentions. The breach is therefore not constituted for this contractual relationship. 48. Regarding the contract concluded with the company [...], the restricted panel notes that the amendment produced by the company in response to the sanction report was concluded on September 7, 2023. The restricted panel notes that this amendment contains all the required mentions but considers that the breach is constituted for the past in light of the date of signature of said amendment. The restricted panel indeed considers that the retroactive nature of the amendment invoked by the company cannot cover the breach for the past insofar as during the checks the concluded contract did not contain the required mentions. 49. Finally, regarding the contract concluded with the company [...], the restricted panel considers that, in light of the documents produced, it is not established that this company processed personal data on behalf of the company PAP and had the status of a processor within the meaning of the GDPR. Therefore, the breach of Article 28 is not characterized. 50. Ultimately, the restricted panel considers that the breach of Article 28, paragraph 3, of the GDPR is established for the past facts concerning the contract governing the relationship with the company [...]. E. On the breaches of the obligation to ensure data security 51. Under Article 32 of the GDPR, "1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including among other things, as necessary: a) the pseudonymization and encryption of personal data; b) the means to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; c) the means to restore the availability of personal data and access to it in a timely manner in the event of a physical or technical incident; d) a procedure for regularly testing, analyzing, and evaluating the effectiveness of technical and organizational measures to ensure processing security." 1. On passwords and confidential references 52. The rapporteur notes that, on the one hand, during the online inspection, the delegation found that when creating a user account on the company's website, passwords of a unique character (one digit or one letter) were accepted and that no access restriction in the event of authentication failure was implemented. Furthermore, the rapporteur notes that, during the checks, each password was stored both in clear text and hashed with the Bcrypt hashing algorithm. 53. On the other hand, the rapporteur notes that, during the on-site inspection, the delegation was informed that when submitting

an advertisement without having an account, the user was provided in clear text with a confidential reference consisting of ten alphanumeric characters, of which the first seven were public as they corresponded to the characters of the reference of the advertisement submitted on the site. This confidential reference could not be modified by the advertiser. This single reference allowed the user to directly access the advertisement and the associated space on the site after entering it in the corresponding field. Moreover, this confidential reference, which resembles a password, was stored in clear text in the database. 54. In defense, the company does not substantially contest the breaches but states that it has taken corrective actions. First of all, it announces that it has adapted its password policy by requiring passwords of a length of eight characters composed of at least one uppercase letter, one lowercase letter, one digit, and one special character. It recalls that now passwords are hashed with the Bcrypt algorithm and that passwords stored in clear text have been deleted. Next, the company specifies that it no longer communicates confidential references to users requiring the creation of an account on the site and has implemented the blocking of the proprietary space after ten unsuccessful login attempts. 55. First and foremost, the restricted panel recalls that it follows from the provisions of Article 32 of the GDPR that the data controller is required to ensure that the automated processing of data that it implements is sufficiently secure. The sufficiency of the security measures is assessed, on the one hand, in light of the characteristics of the processing and the risks it entails, and on the other hand, taking into account the state of knowledge and the cost of the measures.

56. The restricted formation first considers that overly permissive password complexity rules, which allow the use of insufficiently robust passwords, can lead to attacks by unauthorized third parties, such as "brute force" or "dictionary" attacks, which consist of systematically and successively testing numerous passwords and thus lead to a compromise of the associated accounts and the personal data they contain.

57. It notes, in this regard, that the necessity of a strong password is recommended both by the National Cybersecurity Agency (ANSSI) and by the Commission in its deliberation No. 2017-012 of January 19, 2017, adopting a recommendation regarding passwords, a requirement confirmed in its deliberation No. 2022-100 of July 21, 2022.

58. By way of illustration, the restricted formation recalls that the Commission considers in its deliberation No. 2017-012 of January 19, 2017 – which is certainly not imperative but provides relevant insight into the measures to be taken regarding security – that, to ensure a sufficient level of security and confidentiality, in the event that authentication relies solely on an identifier and a password, the latter must consist of at least twelve characters including uppercase letters, lowercase letters, numbers, and special characters.

59. Failing that, the Commission also considers that a sufficient level of security and confidentiality can be ensured by authentication based on a password of a minimum length of eight characters, composed of three different categories of characters but accompanied by a complementary measure such as, for example, account access throttling after several failures (temporary suspension of access with duration increasing with each attempt), the implementation of a mechanism to guard against automated and intensive submission of attempts (e.g., "captcha"), and/or the blocking of the account after several unsuccessful authentication attempts (a maximum of ten).

60. The restricted formation emphasizes that it has adopted financial sanctions where the characterization of a breach of Article 32 of the GDPR results from insufficient measures to ensure the security of the processed data. Deliberations No. SAN-2019-006 of June 13, 2019, No. SAN-2019-007 of July 18, 2019, and No. SAN-2022-018 of September 8, 2022, specifically target the insufficient robustness of passwords.

61. The restricted formation notes that in this case, on the one hand, the passwords of users of the website www.pap.fr had to be, at the time of the checks, composed of a single character and lacked any complementary security measure. It emerges from the company's observations that the required passwords are now of a length of 8 characters composed of at least one uppercase letter, one

lowercase letter, one number, and one special character without any access restriction being provided. On the other hand, the confidential references - comparable to passwords in the sense of the definition in deliberation No. 2022-100 of July 21, 2022, according to which the term password refers to any knowledge factor, namely any set of revocable information, known only to the person concerned and allowing or contributing to their authentication - consisted of ten alphanumeric characters, of which the first seven were public, as they corresponded to the reference of the announcement on the site, with only the last three characters.

privileged. Furthermore, these references were transmitted in clear text and could not be modified by the user, thus constituting a lasting means of authentication. 62. The restricted panel considers that such constructions do not ensure data security and prevent unauthorized third parties from accessing it. 63. Regarding the passwords required at the time of account creation, it recalls, as highlighted by the rapporteur, that the company was processing, at the time of the on-site inspection, data associated with nearly five million user accounts such as name, first name, email address. Thus, these passwords, associated with their identifiers, allow access to all personal data contained in their accounts at www.pap.fr. They were not robust enough, given the personal data at stake and the state of the art. 64. Regarding the confidential reference, the restricted panel considers that the use of this single reference consisting of ten alphanumeric characters did not meet the sufficient complexity criterion. Indeed, it appears that the first part of this reference, the first seven alphanumeric characters corresponding to the advertisement reference, must be considered a public identifier. As for the second part of the reference, composed of the last three alphanumeric characters, which resembles a password, it does not meet the robustness criteria as described earlier. 65. Furthermore, as highlighted by the rapporteur, this confidential reference allows access to the personal data present in the proprietary space associated with the person who published the advertisement, to modify them and also to modify the advertisement. Moreover, access to this space allows access to the exchanges that occurred between the owner and the interested parties regarding the advertisement, during which numerous personal information may be transmitted (family, professional, financial situations). 66. Thus, authentication based on the use, on the one hand, of a password, which is short and lacking additional security measures in the past, currently still insufficiently robust in the absence of additional security measures, and, on the other hand, of a non-modifiable confidential reference, transmitted in clear text and without sufficient complexity, can lead to attacks by unauthorized third parties and thus to a compromise of user accounts and the "proprietary space" and the numerous personal data they contain. 67. Consequently, the restricted panel considers that the password and confidential reference policy deployed was and remains insufficiently robust to guarantee the security of the processed data, which disregards Article 32 of the GDPR. 68. Secondly, the restricted panel recalls that securely storing passwords constitutes a basic precaution in terms of personal data protection. As early as 2013, ANSSI alerted and reminded good practices regarding password storage, indicating that they must "be stored in a transformed form by a one-way cryptographic function (hashing function) that is slow to compute such as PBKDF2" and that "the transformation of passwords must involve a random salt to prevent an attack by precomputed tables" (ANSSI, "CERTA-2013-ACT-046 News Bulletin," November 15, 2013, <https://www.cert.ssi.gouv.fr/actualite/CERTA-2013-ACT-046/>). 69. Similarly, in its deliberation No. 2017-012 of January 19, 2017, CNIL already indicated that it "recommends [that the password] be transformed using a non-reversible and secure cryptographic function (i.e., using a publicly recognized strong algorithm whose software implementation is free of known vulnerabilities), integrating the use of a salt or a key. Indeed, non-robust hash functions have known vulnerabilities that do not guarantee the integrity and confidentiality of passwords in the event of a brute force attack following the compromise of the servers hosting them. 70. In this case, the restricted panel notes that the clear storage, on the one hand, of user passwords, associated with their identifiers and email addresses, and, on the other hand, of confidential references, associated with a personal space, does not guarantee their security. This method of storage implies that anyone with access to the company's customer database – whether it be an information systems administrator of the company or an attacker in the event of a compromise – can consult, collect, modify, or even sell them. 71. Under these conditions, the restricted panel considers that the methods of storing passwords and confidential references did not, at the time of the findings, guarantee the security and confidentiality of the personal

data of account holders, which violates Article 32 of the GDPR. 72. Consequently, the restricted panel considers that the aforementioned facts, uncontested by the company, constitute breaches of the obligations under Article 32 of the GDPR. It acknowledges that since the inspections, the company has partially remedied the identified breaches by implementing a password policy that presents an adequate level of security and by encrypting all passwords.

2. On the retention of data in active database 73. The rapporteur notes that during the inspections, the delegation was informed that all data related to inactive customers was retained for ten years and that data related to inactive user accounts was retained for five years in the active database without any intermediate archiving taking place. 74. In defense, the company contests the existence of the breach. First, it argues that this retention of data in the active database for customers and users who have become inactive is justified by a purpose of combating fraud that requires daily controls. Next, it specifies that only individuals with a legitimate interest in processing the data due to their roles can access personal data, namely customer service advisors, employees from the IT departments, and members of management. In this regard, it adds that these employees are subject to a confidentiality clause and a confidentiality commitment and that each of them has a personal password. 75. The restricted panel recalls that to ensure data security, it is necessary to sort through this data when it is no longer necessary for the purpose for which it was collected. Thus, they must be deleted or subjected to intermediate archiving, which consists notably of physical or logical separation. 76. In the present case, the restricted panel notes that it emerges from the explanations provided by the company that while the purpose of combating fraud may justify data retention, the methods of retaining data in the active database as defined by the company do not ensure data security. On the one hand, the restricted panel notes the significant number of categories of employees who have access to the database, as both customer service advisors, IT department employees, and management members are authorized to access the database. On the other hand, it observes the absence of sorting among the retained data, whereas it appears that the retention of data such as that of the announcement and the billing address is not...

necessary to the objective pursued of combating fraud. The company indeed confirmed during the session that the data used to identify fraudsters was the email address. 77. Consequently, the restricted panel considers that the breach is established. F. On the breach of the obligation to inform and the right to object to commercial prospecting by email for similar products or services. 78. Article L. 34-5 of the Postal and Electronic Communications Code (CPCE) provides that "Direct prospecting by means of automated electronic communication systems [...], a fax machine or emails using the contact details of a natural person [...] who has not previously expressed their consent to receive direct prospecting by this means is prohibited. Direct prospecting is defined as the sending of any message intended to promote, directly or indirectly, goods, services, or the image of a person selling goods or providing services. For the application of this article, calls and messages aimed at encouraging the user or subscriber to call a premium-rate number or to send a premium-rate text message also fall under direct prospecting. However, direct prospecting by email is permitted if the recipient's contact details have been collected from them, in compliance with the provisions of Law No. 78-17 of January 6, 1978 relating to data processing, files, and freedoms, during a sale or service provision, if the direct prospecting concerns similar products or services provided by the same natural or legal person, and if the recipient is expressly and unambiguously offered the possibility to object, at no cost other than those related to the transmission of the refusal, and in a straightforward manner, to the use of their contact details at the time they are collected and each time a prospecting email is sent to them in case they have not initially refused such exploitation." 79. These provisions transpose into French law the rules governing the use of automated calling and communication systems without human intervention (automated calling machines), fax machines, or systems for sending emails for direct prospecting purposes set forth by Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (the so-called "ePrivacy" directive), as amended by Directive 2009/136/EC of November 25, 2009. 80. The rapporteur notes that when a user subscribes to an alert concerning a real estate property, they are likely to receive emails for similar goods or services from the company,

without having been informed or having had the opportunity to object at the time of creating the alert.

81. In defense, the company contests the breach by asserting that the disputed emails do not constitute commercial prospecting since they do not aim to promote goods or services. Furthermore, it argues the low volume of this type of messages and specifies that users have the option to unsubscribe via an unsubscribe link present in each new communication. 82. The restricted panel recalls that under Article L.34-5 of the CPCE, on the one hand, direct commercial prospecting is defined as "any message aimed at the direct or indirect promotion of goods, services, or the image of a person selling goods or providing services." On the other hand, similar products and services, offered during a sale or service provision, must be understood as promoting goods or services of the same natural or legal person without the need for the promotion...

following text is a legal document regarding administrative fines and compliance with data protection regulations:

leads to a financial transaction with the person. 83. The restricted formation considers that the emails sent by the company to users, such as those containing information regarding an advertisement or anonymous surveys on real estate news, arise directly from the subscription to the alert related to a real estate property and are not intended to promote other goods or services offered by the company. Therefore, these emails do not constitute commercial prospecting within the meaning of Article L.34-5 of the CPCE. 84. Under these conditions, the restricted formation considers that the breach of Article L.34-5 of the CPCE is not established.

III. On corrective measures and their publicity 85. Under III of Article 20 of the amended law of January 6, 1978: "When the data controller or its processor fails to comply with the obligations arising from Regulation (EU) 2016/679 of April 27, 2016, or from this law, the president of the National Commission for Information Technology and Civil Liberties may also, if applicable after having sent the warning provided for in I of this article or, if applicable, in addition to a formal notice provided for in II, refer the restricted formation of the commission for the pronouncement, after adversarial proceedings, of one or several of the following measures: [...] 7° Except in cases where the processing is carried out by the State, an administrative fine not exceeding 10 million euros or, in the case of a company, 2% of the total worldwide annual turnover of the previous financial year, the higher amount being retained. In the cases mentioned in 5 and 6 of Article 83 of Regulation (EU) 2016/679 of April 27, 2016, these ceilings are raised, respectively, to 20 million euros and 4% of said turnover. The restricted formation takes into account, in determining the amount of the fine, the criteria specified in the same Article 83." 86. Article 83 of the GDPR provides that "Each supervisory authority ensures that the administrative fines imposed [...] are, in each case, effective, proportionate, and dissuasive," before specifying the elements to be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine.

A. On the pronouncement of an administrative fine and its amount 1. On the pronouncement of an administrative fine 87. In defense, the company considers that the proposed administrative fine is disproportionate in relation to the alleged breaches and its conduct since it has implemented several corrective measures before the end of the investigation, in particular, the modification of its privacy policy to provide the required information, the use of subcontractors governed by a legal act containing all the required mentions, and the establishment of a password policy and storage presenting an adequate level of security. Furthermore, it emphasizes having fully cooperated with the services of the CNIL. It adds that it has not derived any financial advantage from the alleged breaches. It argues that its turnover is stagnant and that the real estate sector, particularly competitive, is in crisis. Finally, it considers that the fine of 250,000 euros proposed by the rapporteur amounts to [...] % of its turnover for 2023 and is, therefore, excessive. 88. The restricted formation recalls that it must take into account, for the pronouncement of an administrative fine, the criteria specified in Article 83 of the GDPR, such as the nature, gravity, and duration of the violation, the scope or purpose of the processing concerned, the number of persons affected, the measures taken by the data controller to mitigate the damage suffered by the affected individuals, the fact that the violation was committed negligently, the degree of

cooperation with the supervisory authority, and, in certain cases, the level of damage suffered by individuals. 89. The

Please let me know if you need further assistance or additional translations.

****Restricted Formation**** first notes that the breaches attributed to the company affect fundamental principles provided by the GDPR and concern numerous individuals.

90. Regarding the breach of the principle of data retention limitation, the company has shown negligence, on the one hand, by not adequately defining a retention period for the data of customers who entered into a contract for less than 120 euros and, on the other hand, by not applying the retention period it had defined for user data at the time of the inspections. The restricted formation notes that this breach concerns a significant number of individuals, with the company counting 2,394,538 users whose last connection to their account dated back between five and ten years from the date of the inspections.

91. Regarding the breach of the obligation to inform the data subjects and to ensure transparency, the restricted formation notes that the company failed to provide complete and transparent information to the data subjects, which constitutes an essential prerequisite for any processing of personal data.

92. Regarding the breach of the obligation to formalize the processing carried out on behalf of the data controller through a legal act, the restricted formation notes that the company lacked rigor by not ensuring the subscription to a contractual document containing the required mentions under Article 28 of the GDPR, thus depriving the data subjects of benefiting from full protection of their personal data.

93. Regarding the breach of the obligation to ensure the security of personal data, the restricted formation emphasizes the number of breaches observed regarding basic security obligations, namely, the use of a password and a confidential reference that were insufficiently robust for customer or user accounts, the unencrypted transmission of the confidential reference, the unencrypted storage of passwords and confidential references, as well as the retention of data in an active database. The restricted formation believes that the accumulation of these security flaws did not allow individuals to benefit from the full protection provided by the GDPR concerning the use of their data.

94. Finally, while taking into account that the company has implemented measures following the notification of the sanction report, the restricted formation notes that these actions do not exempt the company from its responsibility for the breaches committed in the past.

95. Consequently, the restricted formation considers that it is appropriate to impose an administrative fine for the breaches of Articles 5-1-e), 13, 28, and 32 of the GDPR.

****2. On the amount of the administrative fine****

96. The restricted formation first notes that the breaches of Articles 5-1-e) and 13 of the GDPR constitute breaches of key principles of the GDPR that may be subject, under Article 83 of the GDPR, to an administrative fine of up to 20,000,000 euros or up to 4% of the annual turnover, with the higher amount being retained.

97. The restricted formation notes that the company achieved a turnover of approximately [...] euros in 2022, with a net result of [...].

98. Therefore, in light of the company's responsibility, its financial capacities, and the relevant criteria of Article 83 of the Regulation, the restricted formation believes that an administrative fine of a total amount of one hundred thousand (100,000) euros for the breaches of Articles 5-1-e), 13, 28, and 32 of the GDPR appears justified.

****B. On the publicity****

99. The restricted formation considers that the publicity of this decision is justified in view of the seriousness of the breaches in question and the number of individuals concerned. It also considers that the publicity of the sanction will notably inform all individuals affected by the breaches.

100. Finally, the measure is proportionate since the decision will no longer specifically identify the company after a period of two years from its publication.

****FOR THESE REASONS****

The restricted formation of the CNIL, after deliberation, decides to:

- impose an administrative fine of one hundred thousand (100,000) euros against the company DE PARTICULIER A PARTICULIER – EDITIONS NERESSIS for breaches of Articles 5-1-e), 13, 28, and 32 of Regulation (EU) No. 2016/679 of April 27, 2016, concerning the protection of personal data;
- make its deliberation public on the CNIL website and on the Légifrance website, which will no longer specifically identify the company after a period of two years from its publication.

****The President****

Alexandre LINDEN

This decision may be subject to appeal before the Council of State within two months from its notification.